ĐÁNH GIÁ AN TOÀN THÔNG TIN ỨNG DỤNG WEB

Trần Tăng Trường Thịnh **2387701939**

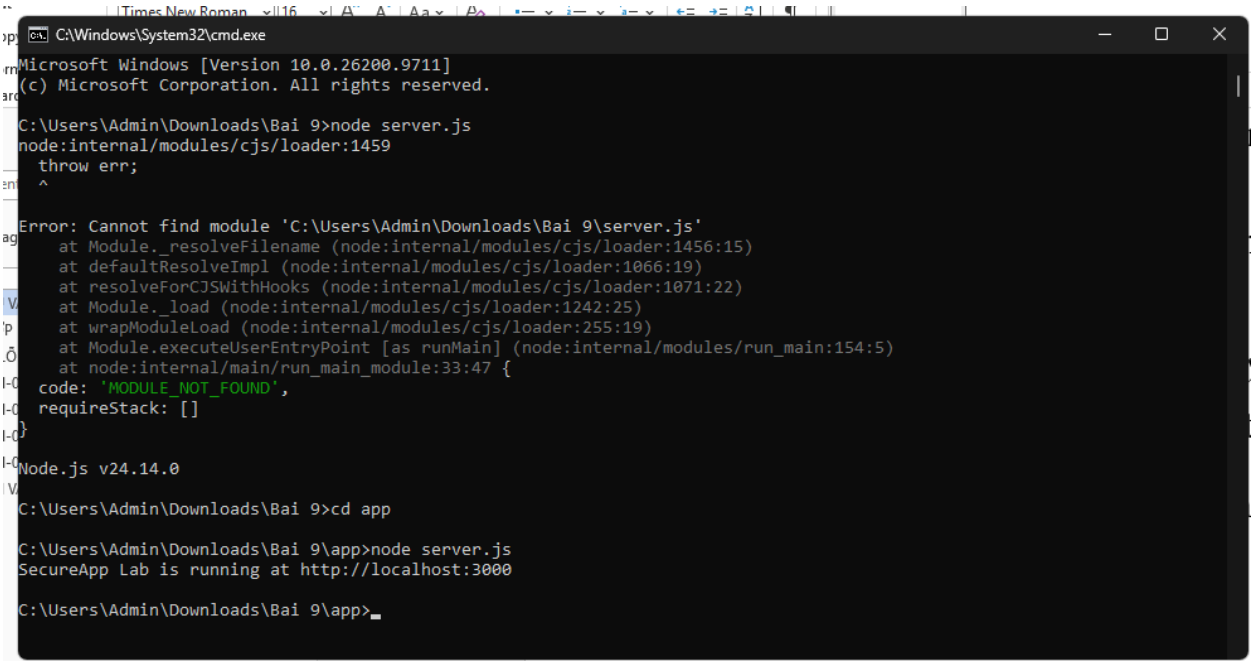
BÀI THỰC HÀNH SỐ 9: ĐÁNH GIÁ VÀ BÁO CÁO LỖ HỔNG WEB THEO CHUẨN OWASP

---

1. MỤC TIÊU VÀ PHẠM VI ĐÁNH GIÁ (SCOPE)

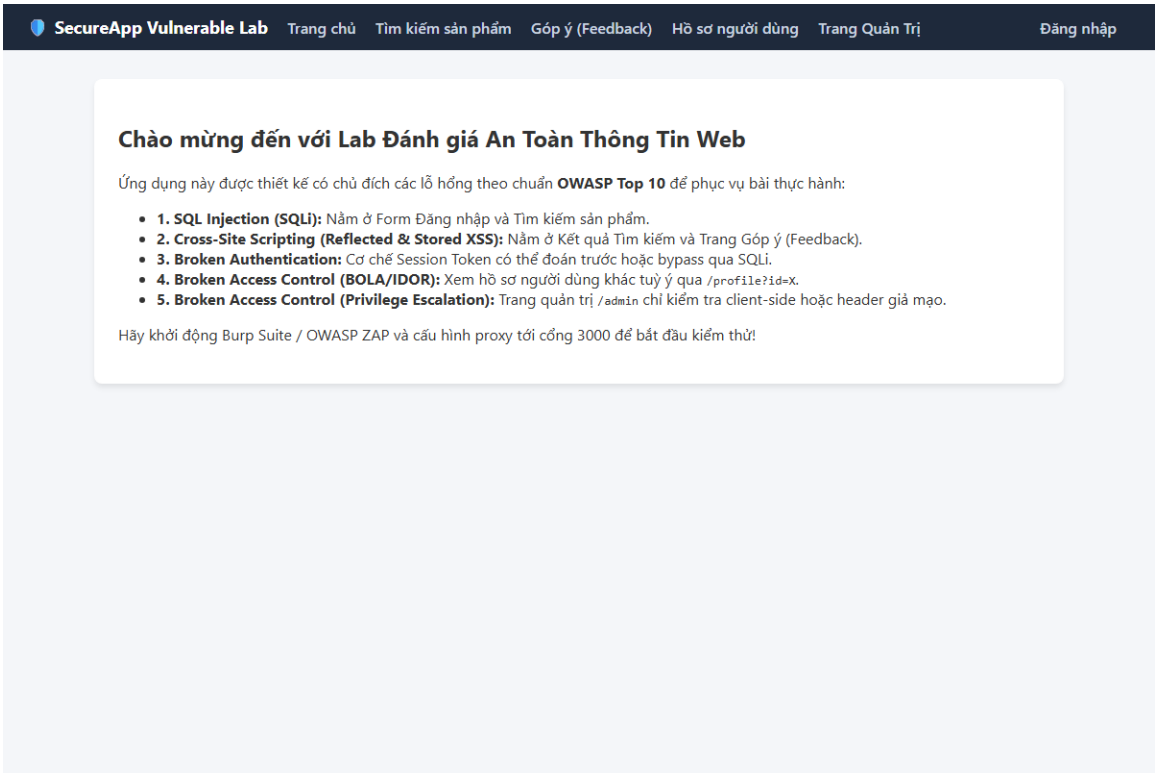
• **Mục tiêu:** Thực hành quy trình rà soát, đánh giá an toàn thông tin trên ứng dụng web mẫu; phát hiện các lỗ hổng bảo mật phổ biến theo OWASP Top 10; chụp lại bằng chứng khai thác và đề xuất biện pháp khắc phục kỹ thuật.

• **Công cụ sử dụng:** Burp Suite Community Edition, Trình duyệt Web (Chrome/Firefox/Playwright), Python PoC Automation.



Hình 1: Khởi động môi trường web lab

Giao diện tổng quan của Ứng dụng Web Lab mục tiêu:



Hình 2: Giao diện Trang chủ SecureApp Vulnerable Lab

2. TỔNG HỢP KẾT QUẢ ĐÁNH GIÁ (EXECUTIVE SUMMARY)

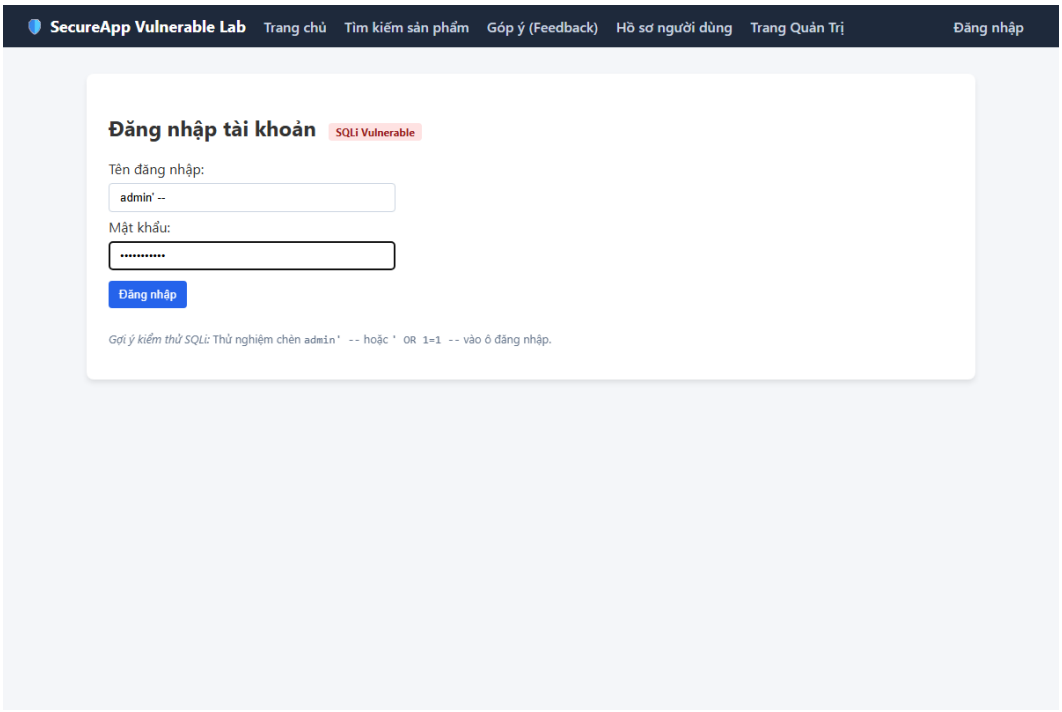
Mã lỗ hổng	Tên lỗ hổng bảo mật	Vị trí / Endpoint	Mức độ rủi ro	OWASP Category
VULN-01	SQL Injection (Auth Bypass & UNION)	/login & /products	**CRITICAL (9.8)**	A03:2021 - Injection
VULN-02	Reflected Cross-Site Scripting (XSS)	/products?q=	**HIGH (8.2)**	A03:2021 - Injection
VULN-03	Stored Cross-Site Scripting (XSS)	/feedback	**HIGH (8.0)**	A03:2021 - Injection
VULN-04	Insecure Direct Object Reference (IDOR)	/profile?id=	**HIGH (7.5)**	A01:2021 - Broken Access Control
VULN-05	Privilege Escalation via Header Bypass	/admin	**CRITICAL (9.1)**	A01:2021 - Broken Access Control

3. CHI TIẾT LỖ HỔNG VÀ BẰNG CHỨNG KHAI THÁC (PROOF OF CONCEPT)

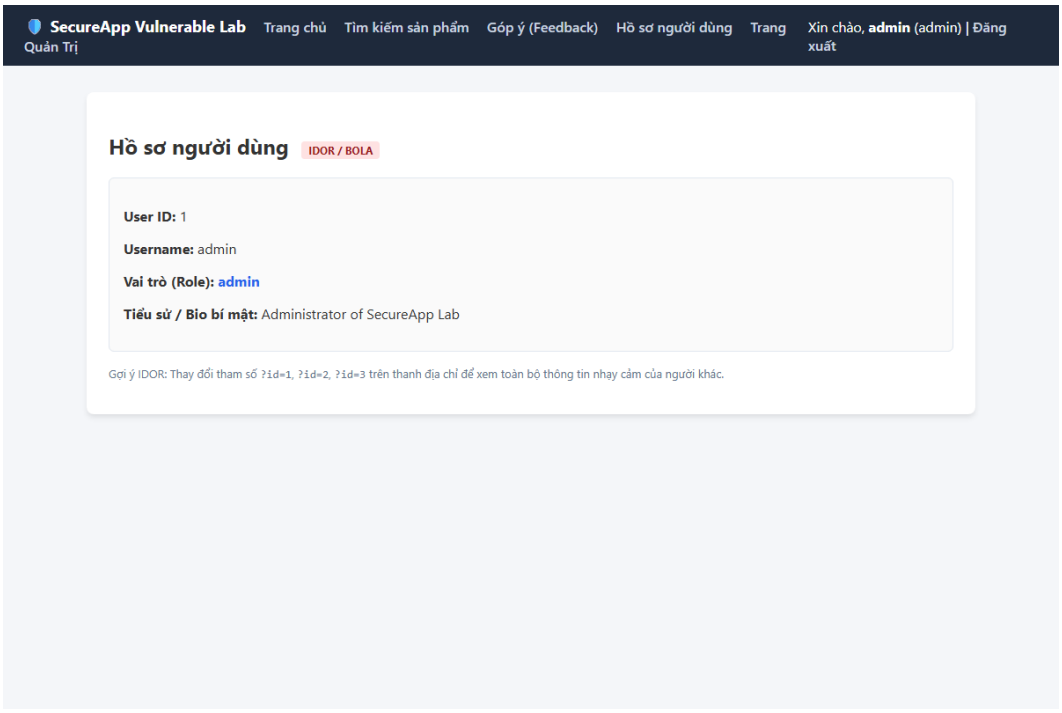
3.1. VULN-01: SQL Injection (Bypass Authentication & Data Leak)

• **Mô tả:** Ứng dụng thực hiện nối chuỗi đầu vào của người dùng trực tiếp vào câu lệnh SQL mà không sử dụng cơ chế Parameterized Query / Prepared Statements.

• **Khai thác Vượt qua Đăng nhập:** Tại form đăng nhập /login, truyền payload: **admin' --** vào trường username. Khi đó câu truy vấn thành: SELECT * FROM users WHERE username = 'admin' -- AND password = '...'. Đoạn kiểm tra mật khẩu bị comment bỏ qua hoàn toàn.

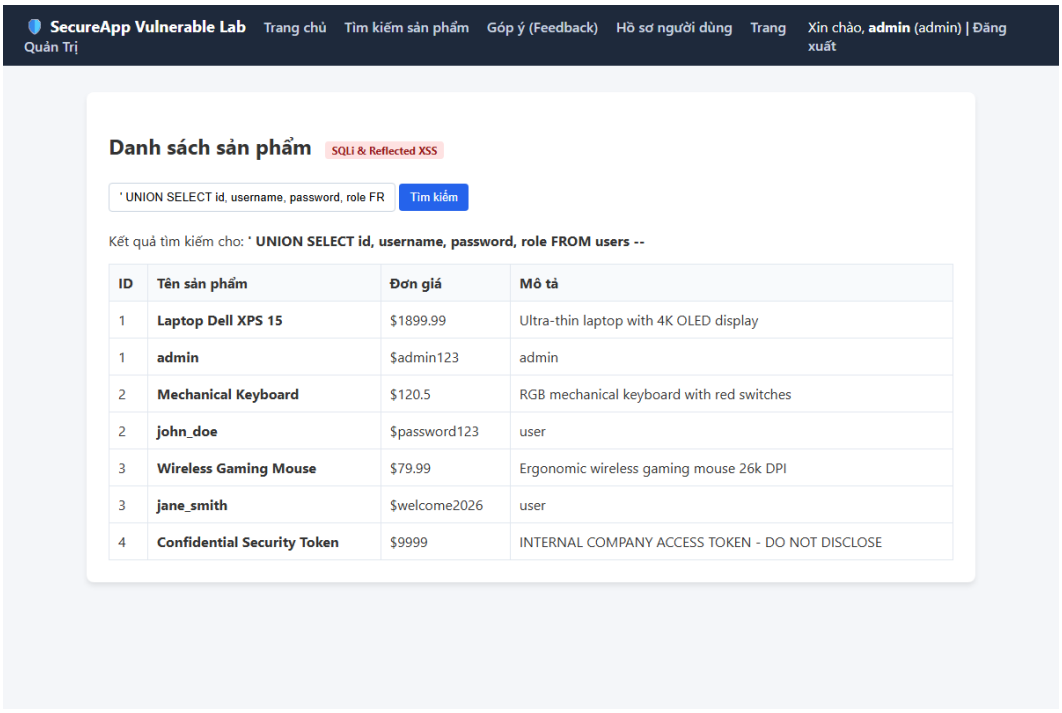


Hình 3: Chèn payload SQLi admin' -- vào form Đăng nhập



Hình 4: Đăng nhập thành công vào tài khoản Quản trị viên (admin) mà không cần mật khẩu

• **Khai thác Trích xuất Dữ liệu (UNION-based):** Tại ô tìm kiếm /products, chèn payload: ' UNION SELECT id, username, password, role FROM users --. Hệ thống trích xuất toàn bộ bảng users (bao gồm mật khẩu dạng thô) lên màn hình sản phẩm.



Hình 5: Toàn bộ thông tin tài khoản và mật khẩu bị lộ do UNION SQL Injection

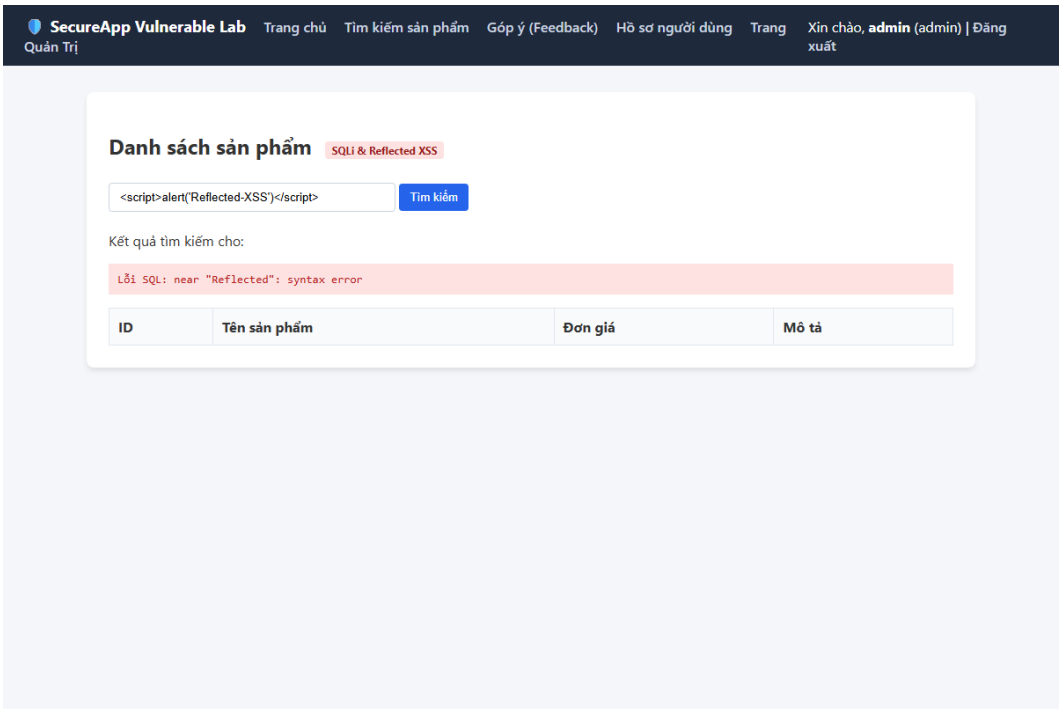
✓ **Giải pháp khắc phục:** Sử dụng Prepared Statements (Parameterized Queries) của SQLite / ORM. Tuyệt đối không nối chuỗi dữ liệu người dùng vào câu lệnh SQL.

3.2. VULN-02 & VULN-03: Cross-Site Scripting (Reflected & Stored XSS)

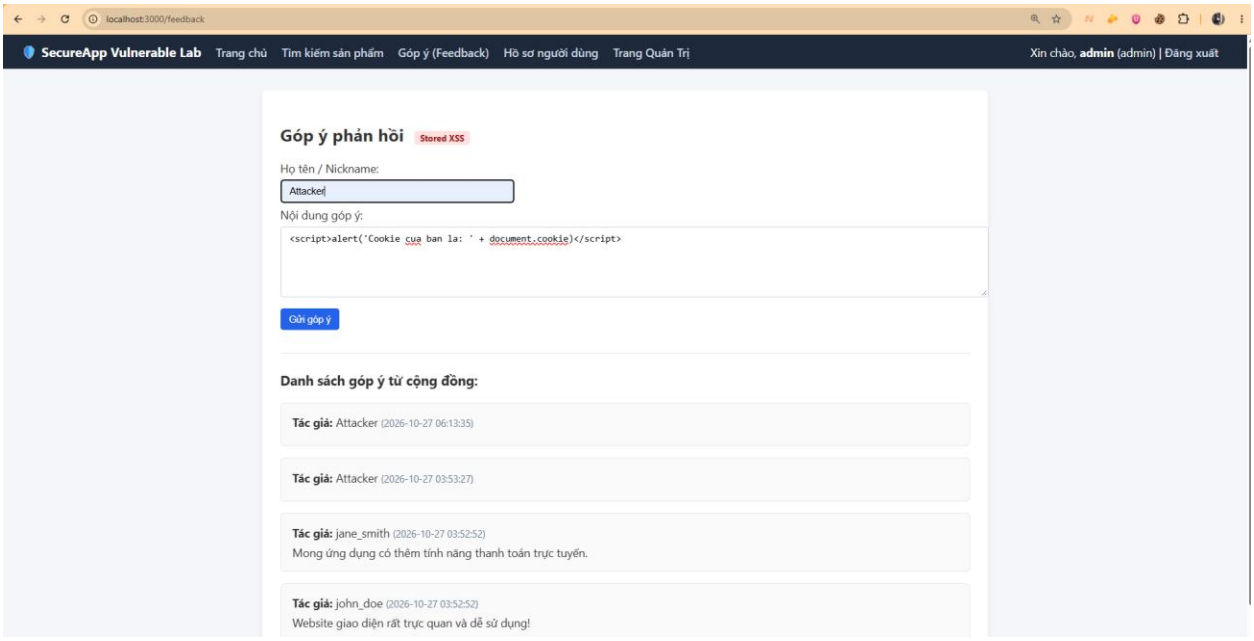
• **Mô tả:** Ứng dụng in trực tiếp dữ liệu do người dùng nhập vào giao diện HTML mà không qua bộ lọc mã hóa thực thể (HTML Entity Encoding).

• **Reflected XSS:** Tại trang tìm kiếm /products?q=<script>alert('Reflected-XSS')</script>, script lập tức được thực thi trong phiên làm việc của nạn nhân khi mở liên kết.

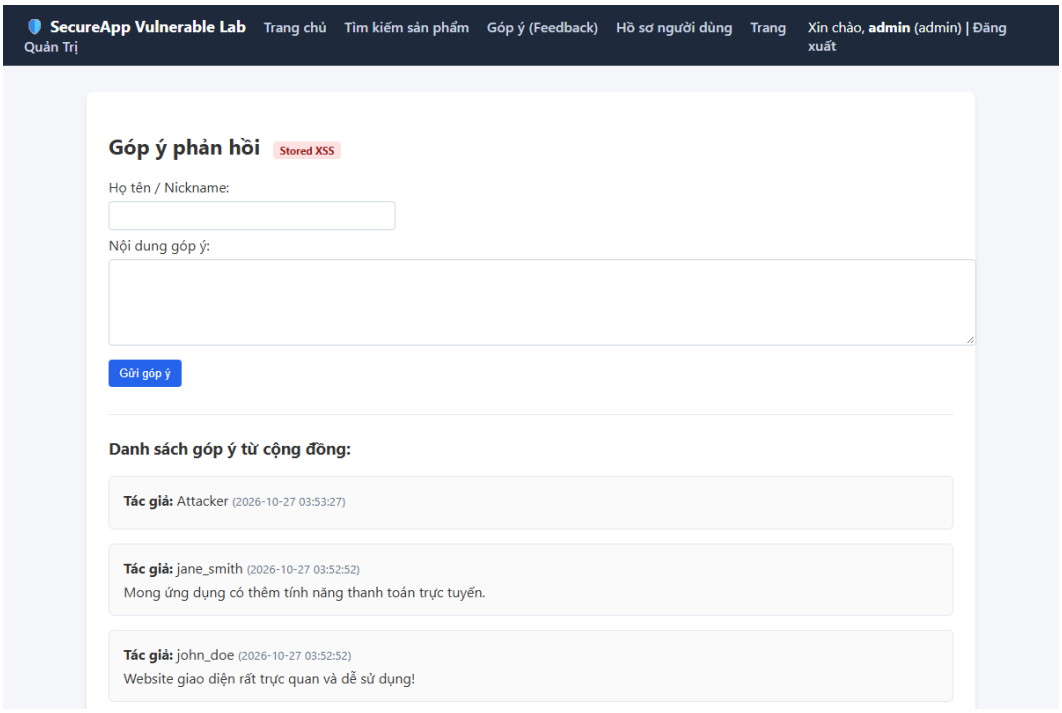
• **Stored XSS:** Tại form góp ý /feedback, kẻ tấn công gửi payload: <script>alert(document.cookie)</script>. Mã độc được lưu cố định vào cơ sở dữ liệu và tự động kích hoạt mỗi khi người dùng khác truy cập.



Hình 6: Khai thác thành công Reflected XSS trên chức năng tìm kiếm sản phẩm



Hình 7: Chèn payload Stored XSS <script>alert('Cookie cua ban la: ' + document.cookie)</script> vào ô Nội dung góp ý tại trang /feedback.

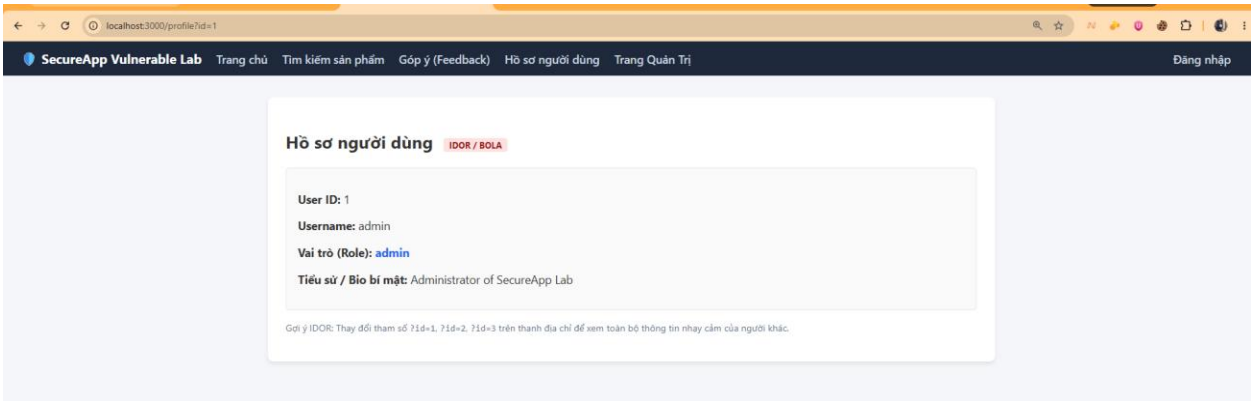


Hình 8: Stored XSS được lưu vào hệ thống và hiển thị trong danh sách Góp ý

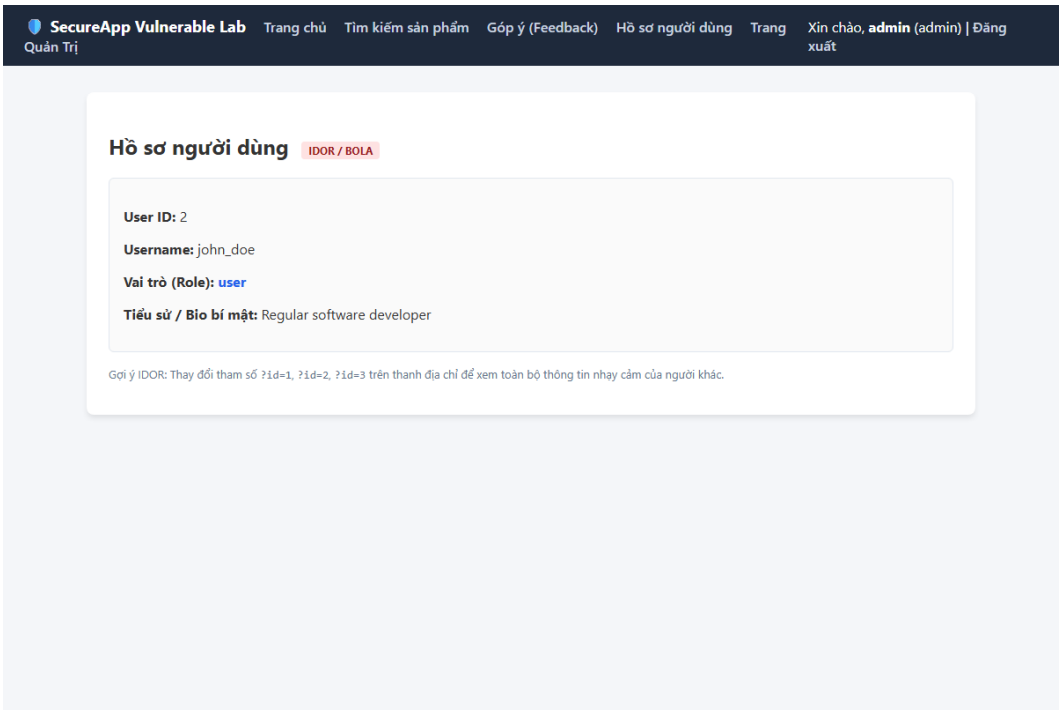
✓ **Giải pháp khắc phục:** Mã hóa toàn bộ đầu ra (Output Encoding) bằng các hàm encodeHTML; Thiết lập Content Security Policy (CSP); Bổ sung cờ HttpOnly cho Cookie để chống đánh cắp phiên.

3.3. VULN-04: Insecure Direct Object Reference (IDOR / BOLA)

• **Mô tả:** Tại chức năng xem hồ sơ /profile?id=X, máy chủ chỉ nhận tham số id từ URL và truy vấn trả về dữ liệu mà không hề xác thực người gửi yêu cầu có phải là chủ sở hữu tài nguyên hay không.



Hình 9: Đọc trộm hồ sơ admin bằng cách thay đổi ?id=1

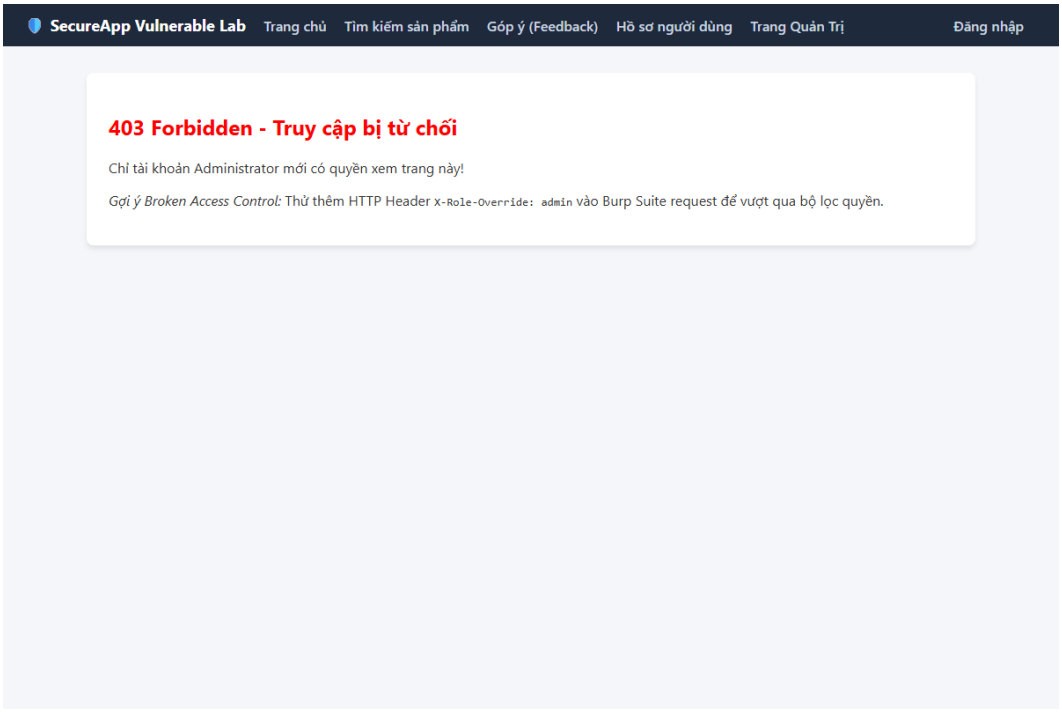


Hình 10: Đọc trộm hồ John Doe bằng cách thay đổi ?id=2

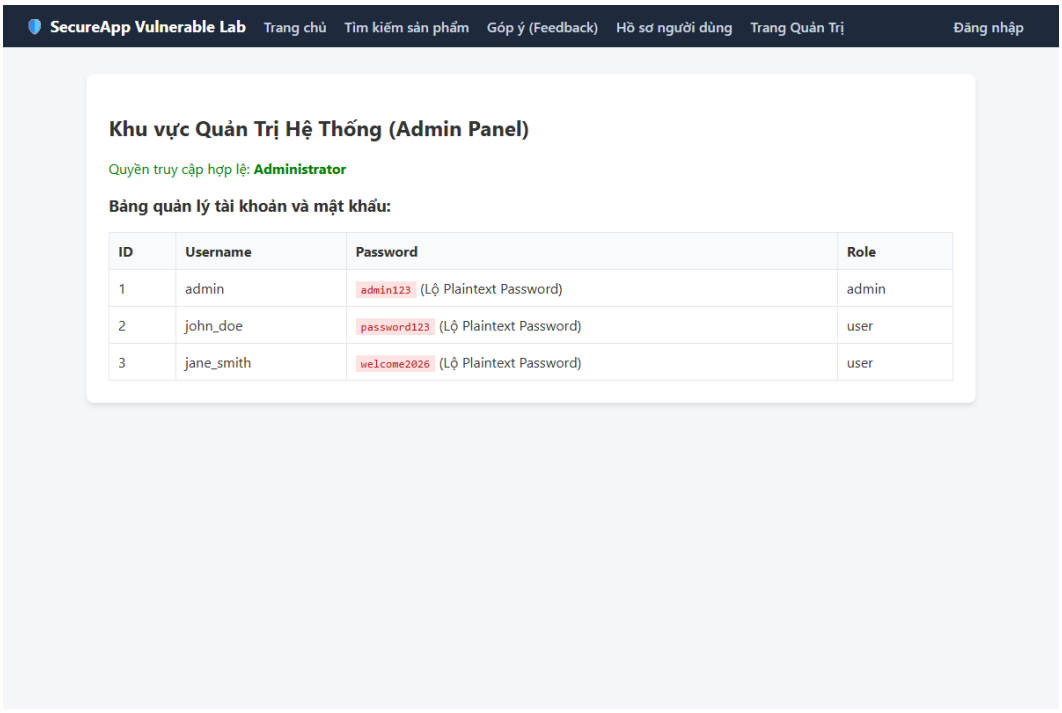
✓ **Giải pháp khắc phục:** Kiểm tra quyền sở hữu (Access Control Check) tại tầng backend trước khi trả về dữ liệu: req.user.id === requestedId.

3.4. VULN-05: Broken Access Control & Privilege Escalation trên /admin

• **Mô tả:** Trang quản trị /admin chặn người dùng thông thường bằng mã 403 Forbidden. Tuy nhiên, mã nguồn lại tin cậy HTTP Header X-Role-Override: admin do client gửi lên.



Hình 11: Truy cập thông thường vào /admin bị từ chối (403 Forbidden)



Hình 12: Leo thang đặc quyền Admin thành công khi chèn Header X-Role-Override: admin

✓ **Giải pháp khắc phục:** Không bao giờ tin tưởng các HTTP Header do client tự gửi lên để phân quyền. Phân quyền người dùng bắt buộc phải được xác minh từ Session/Token phía Server.

4. KẾT LUẬN VÀ BÀI HỌC KINH NGHIỆM

Bài thực hành đã giúp nắm vững quy trình kiểm thử đánh giá an toàn thông tin theo chuẩn công nghiệp:

1. Thu thập thông tin và lập bản đồ các chức năng trọng yếu (Authentication, Search, User Input, Admin Control).
2. Sử dụng công cụ Proxy (Burp Suite) để can thiệp, chỉnh sửa tham số và gửi payload tấn công.
3. Xác định bản chất lỗ hổng từ mã nguồn và đề xuất biện pháp phòng vệ theo chiều sâu (Defense-in-depth).